

REDES Y SEGURIDAD II



Gestión de la Seguridad



Contenidos

1. Legislación sobre seguridad
2. Sistema de Gestión de la Seguridad de la Información
3. Gestión de incidentes
4. Plan de recuperación



Legislación sobre seguridad

RGPD (Reglamento General de Protección de Datos)

- Normativa europea en vigor desde 2018 que protege los datos personales de los ciudadanos de la UE.
- **Objetivo:** garantizar que las organizaciones recojan, almacenen y procesen datos personales de forma segura y con consentimiento explícito.
- **Puntos clave:**
 - Derechos de los ciudadanos (acceso, rectificación, olvido, portabilidad).
 - Obligación de informar sobre el uso de datos (políticas de privacidad claras).
 - Notificación de brechas de seguridad en un máximo de 72h.
 - Sanciones muy elevadas (hasta el 4% de la facturación anual).
- **Ejemplo:** una empresa que envía correos publicitarios sin consentimiento puede ser multada por la AEPD.



Legislación sobre seguridad

NIS2 (Network and Information Security Directive 2)

- Directiva europea de 2023 que sustituye a la NIS original.
- Regula la ciberseguridad en sectores críticos.
- **Objetivo:** elevar el nivel común de ciberseguridad en la UE, especialmente en servicios esenciales.
- **Puntos clave:**
 - Medidas técnicas y organizativas para gestionar riesgos.
 - Gestión de incidentes: detección, respuesta y reporte.
 - Informar a las autoridades nacionales (INCIBE en España) en caso de incidente grave.
- **Ejemplo:** un hospital víctima de ransomware debe notificarlo y tener planes de continuidad para seguir atendiendo pacientes.



Legislación sobre seguridad

eIDAS (electronic IDentification, Authentication and trust Services)

- Reglamento europeo de 2014 que regula la identidad digital y servicios de confianza.
- Actualización en 2024, conocido como eIDAS 2.
- **Objetivo:** facilitar las transacciones electrónicas seguras entre ciudadanos, empresas y administraciones públicas.
- **Servicios de confianza:**
 - Firma electrónica y sello electrónico.
 - Sello de tiempo.
 - Certificados digitales para autenticación.
 - Entrega electrónica certificada.
- **Novedad con eIDAS 2:** creación de la Cartera de Identidad Digital Europea, para identificarse en toda la UE con el móvil.
- **Ejemplo:** firmar un contrato de alquiler online con una firma electrónica cualificada tiene el mismo valor legal que firmarlo en papel.

Legislación sobre seguridad

Resumen

- **RGPD** protege datos personales.
- **NIS2** protege infraestructuras y servicios críticos.
- **eIDAS2** protege y regula la identidad digital y las transacciones electrónicas.



Legislación sobre seguridad

Esquema Nacional de Seguridad (ENS)

- Marco normativo que obliga a las administraciones públicas (y a las empresas que trabajan con ellas) a aplicar medidas de seguridad de la información proporcionales al riesgo y al impacto de los servicios que prestan.
- **Objetivo:**
 - Proteger la **confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad** de la información manejada por el sector público.
 - Homogeneizar la seguridad en todas las administraciones públicas y en los proveedores que trabajan con ellas.





Legislación sobre seguridad

Esquema Nacional de Seguridad (ENS)

- **Componentes principales:**

- **Principios básicos:** prevención, detección, corrección, proporcionalidad.
- **Requisitos mínimos:** organización, gestión de riesgos, protección de instalaciones, control de accesos, registro de actividad, continuidad, etc.
- **Categorías de sistemas:** Bajo, Medio o Alto (según el impacto que tendría un incidente en la prestación de servicios).

- **Criterios de clasificación ENS:**

- Se evalúan principalmente estas dimensiones de seguridad:
 - **Disponibilidad:** ¿qué pasa si el sistema no funciona?
 - **Confidencialidad:** ¿qué pasa si se filtran datos?
 - **Integridad:** ¿qué pasa si la información se manipula?
 - **Autenticidad:** ¿qué pasa si no se puede garantizar la identidad de usuarios o procesos?
 - **Trazabilidad:** ¿qué pasa si no hay registro de acciones?
- El nivel final (Bajo, Medio, Alto) será el máximo obtenido entre todas las dimensiones.



Legislación sobre seguridad

LOPDGDD (Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales)

- Ley española que adapta el RGPD europeo al contexto nacional y desarrolla algunos derechos digitales.
- En vigor desde diciembre de 2018.
- **Objetivo:**
 - Proteger los datos personales de los ciudadanos españoles.
 - Garantizar derechos digitales en entornos laborales, educativos y públicos.
- **Puntos clave**
 - Derechos de los ciudadanos: acceso, rectificación, cancelación, oposición, portabilidad, olvido.
 - Reglas de consentimiento: debe ser libre, informado, específico e inequívoco.
 - Obligación de notificar brechas de seguridad a la AEPD en un máximo de 72 horas.
 - Inclusión de los Derechos Digitales:
 - Derecho a la desconexión digital en el trabajo.
 - Protección frente a ciberacoso laboral.
 - Derechos sobre algoritmos y decisiones automatizadas.
- **Ejemplo:** Una empresa que recopila datos de clientes debe informar explícitamente del uso de esos datos y permitir que el cliente los borre si lo solicita.



Legislación sobre seguridad

Código Penal (artículos sobre delitos informáticos)

- Conjunto de normas penales españolas que incluyen delitos relacionados con sistemas de información y datos.
- **Objetivo:** Sancionar conductas ilícitas que afectan a la seguridad de la información y los sistemas informáticos.
- **Delitos más relevantes en seguridad de la información**
 - **Acceso ilícito a sistemas** (hacking) → art. 197 bis y siguientes.
 - **Intercepción de comunicaciones** (espionaje de datos) → art. 197.
 - **Daño informático** (virus, ransomware, destrucción de datos) → art. 264 y 264 bis.
 - **Estafas y fraudes electrónicos** → art. 248 y 249.
 - **Revelación de secretos** (datos personales, confidenciales) → art. 197.
- **Ejemplo:** Un empleado que filtra información de clientes a un competidor podría ser sancionado penalmente según el Código Penal, además de enfrentar sanciones administrativas por la LOPDGDD.



Legislación sobre seguridad

Resumen

- **LOPDGDD** regula cómo deben tratarse los datos, con sanciones administrativas.
- **Código Penal** regula conductas delictivas relacionadas con datos e información, con sanciones penales (multas, prisión).

Ejemplo: un cibercriminal que roba datos personales comete delito penal (Código Penal) y la empresa afectada puede denunciarlo y aplicar la LOPDGDD para proteger a los usuarios.



Legislación sobre seguridad

Responsabilidad

- Obligación de una organización o persona de cumplir la normativa de seguridad y proteger la información, así como de responder por incidentes o incumplimientos.
- **Tipos:**
 - **Responsabilidad legal:** por incumplimiento de leyes (RGPD, LOPDGDD, Código Penal).
 - **Responsabilidad corporativa:** por no aplicar políticas de seguridad internas o estándares como ENS / ISO 27001.
 - **Responsabilidad individual:** directivos o empleados pueden responder si cometen negligencia o actuaciones ilícitas.
- **Ejemplo:** un responsable de tratamiento que no protege datos personales puede ser sancionado personalmente y la empresa también.



Legislación sobre seguridad

Sanciones

- **Administrativas:**

- Multas por incumplir RGPD o LOPDGDD.
- Ejemplo: hasta 20 millones € o 4% facturación anual (RGPD).

- **Penales:**

- Delitos informáticos: hacking, revelación de secretos, sabotaje de sistemas → Código Penal.
- Puede incluir prisión o multas.

- **Reputacionales:**

- Pérdida de confianza, imagen pública dañada, pérdida de clientes o contratos.



Legislación sobre seguridad

Trazabilidad

- Capacidad de registrar, monitorizar y auditar todas las acciones realizadas sobre datos o sistemas, de manera que se pueda reconstruir un incidente.
- **Objetivo:** identificar responsables, entender causas y evitar que vuelva a ocurrir.
- **Cómo se implementa:**
 - Logs de acceso y actividad de usuarios.
 - Registros de cambios en sistemas y bases de datos.
 - Control de permisos y roles.
- **Ejemplo:** si un usuario borra accidentalmente registros de clientes, los logs permiten saber quién lo hizo, cuándo y con qué sistema, facilitando la recuperación y la investigación.



Sistema de Gestión de la Seguridad de la Información

ISO/IEC 27001

- Norma internacional que define los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI).
- **Objetivo:** proteger la confidencialidad, integridad y disponibilidad de la información mediante un enfoque sistemático basado en riesgos.
 - Aplicable a cualquier organización, independientemente de tamaño o sector.
- **Beneficios:**
 - Gestión estructurada de riesgos.
 - Mejora continua de la seguridad.
 - Cumplimiento legal y normativo (RGPD, ENS, etc.).



Sistema de Gestión de la Seguridad de la Información

Ciclo PDCA (Plan–Do–Check–Act)

- Modelo de mejora continua que guía la implantación de la ISO 27001:

Fase	Significado	Ejemplo
Plan (Planificar)	Establecer el SGSI, definir políticas, objetivos, identificar riesgos y controles.	Realizar un análisis de riesgos sobre los sistemas de información de la empresa.
Do (Hacer)	Implementar las políticas, procedimientos y controles definidos.	Configurar firewalls, control de accesos y cifrado según los riesgos identificados.
Check (Verificar)	Monitorizar, medir y evaluar la eficacia del SGSI.	Revisar logs, auditorías internas y reportes de incidentes.
Act (Actuar)	Tomar acciones correctivas y de mejora continua según los resultados.	Actualizar procedimientos, reforzar controles o capacitar al personal.



Sistema de Gestión de la Seguridad de la Información

ISO 22301: Gestión de la Continuidad del Negocio (BCM)

- Norma internacional que define los requisitos para un Sistema de Gestión de Continuidad del Negocio (BCMS).
- **Objetivo:** asegurar que una organización pueda seguir operando y recuperarse rápidamente ante incidentes graves (desastres, ciberataques, fallos de sistemas, pandemias, etc.).
- **Alcance:** cualquier organización que quiera garantizar la continuidad de sus procesos críticos.



Sistema de Gestión de la Seguridad de la Información

Relación ISO 22301 con ISO/IEC 27001

- **ISO 27001** se centra en proteger la información mediante un SGSI.
- **ISO 22301** se centra en garantizar la continuidad de procesos críticos frente a incidentes o interrupciones.
- Ambas buscan gestión de riesgos y preparación ante incidentes, y pueden integrarse en un sistema de gestión único:
 - SGSI protege la información → reduce riesgos de incidentes.
 - BCMS asegura que, si ocurre un incidente, los procesos esenciales siguen funcionando o se recuperan rápidamente.



Sistema de Gestión de la Seguridad de la Información

ISO/IEC 27002: Código de buenas prácticas en seguridad de la información

- Norma internacional que proporciona buenas prácticas y controles de seguridad de la información.
- **Objetivo:** guiar a las organizaciones sobre cómo implementar los controles que la ISO 27001 requiere.
- **Relación con ISO 27001:**
 - ISO 27001 establece “**qué**” debe hacerse (requisitos de un SGSI).
 - ISO 27002 explica “**cómo**” implementarlo mediante controles y buenas prácticas.



Sistema de Gestión de la Seguridad de la Información

Categorías de controles según ISO 27002

- **Políticas de seguridad:** definir objetivos y reglas claras de seguridad.
- **Organización de la seguridad:** roles, responsabilidades y segregación de funciones.
- **Seguridad de recursos humanos:** formación, control previo y final de empleados.
- **Gestión de activos:** inventario de activos, clasificación y protección de la información.
- **Control de accesos:** autenticación, permisos, gestión de cuentas.
- **Criptografía:** cifrado de datos, firmas digitales y gestión de claves.
- **Seguridad física y ambiental:** control de accesos a instalaciones, protección de equipos.
- **Operaciones y comunicaciones:** monitorización, control de cambios, copias de seguridad, gestión de incidentes.
- **Seguridad en sistemas de información:** desarrollo seguro, gestión de vulnerabilidades.
- **Relaciones con proveedores:** garantizar seguridad en proveedores y contratos.
- **Gestión de incidentes de seguridad:** detección, respuesta y aprendizaje.
- **Aspectos de continuidad del negocio:** recuperación ante desastres y planes de contingencia.
- **Cumplimiento:** leyes, normativa, auditorías y requisitos contractuales.



Sistema de Gestión de la Seguridad de la Información

Política de Seguridad de la Información

- Documento estratégico aprobado por la dirección de la organización que define:
 - Objetivos de seguridad.
 - Compromiso de la dirección.
 - Principios básicos para proteger la información.
- Incluye:
 - **Alcance:** qué sistemas, procesos y personas abarca.
 - **Principios:** confidencialidad, integridad, disponibilidad.
 - **Normas generales:** contraseñas, acceso a la información, uso de dispositivos, etc.
 - **Roles y responsabilidades:** quién hace qué en seguridad.
 - **Referencia a cumplimiento legal:** RGPD, ENS, ISO 27001, etc.

Sistema de Gestión de la Seguridad de la Información

Gestión de Riesgos en Seguridad de la Información

- Proceso para identificar, analizar y tratar los riesgos que amenazan a la información y los sistemas.
- Es la base de la ISO 27001: todo control debe estar justificado por un riesgo real.

Etapas principales (según ISO 27005, MAGERIT, OCTAVE...)

1. Identificación de activos: qué información y sistemas son críticos.
2. Identificación de amenazas: qué puede pasar.
3. Identificación de vulnerabilidades: puntos débiles.
4. Evaluación del riesgo: probabilidad $\times$ impacto.
5. Tratamiento del riesgo: Reducir, Transferir, Aceptar o Evitar.

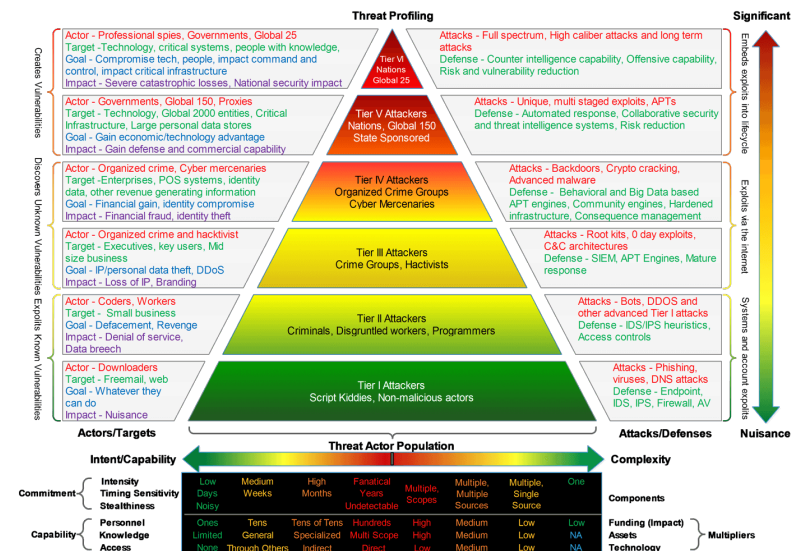




Gestión de incidentes

Tipos de incidentes

- **Ciberataques:** ataques intencionados por parte de terceros.
- **Fugas de datos:** exposición, pérdida o robo de información sensible o confidencial.
- **Fallos humanos:** errores involuntarios de usuarios o administradores que afectan a la seguridad.





Gestión de incidentes

Ciclo de Vida de la Gestión de Incidentes

1. **Detección y notificación:** identificar que algo anómalo está ocurriendo.
2. **Análisis:** confirmar si realmente es un incidente y evaluar su alcance.
3. **Contención:** limitar los daños evitando que el incidente se expanda.
4. **Erradicación:** eliminar la causa raíz del incidente.
5. **Recuperación:** restaurar los servicios afectados de forma segura.
6. **Lecciones aprendidas (NIST / ISO 27035):** analizar qué falló y cómo evitar que se repita.



Gestión de incidentes

Roles y responsabilidades

- **CSIRT (Computer Security Incident Response Team)**
 - Equipo especializado en **gestionar incidentes de seguridad**.
 - **Responsabilidades principales:**
 - Recepción y análisis de incidentes.
 - Coordinación de respuesta (contención, erradicación, recuperación).
 - Comunicación con afectados y autoridades.
 - Elaborar informes post-mortem y recomendaciones.
 - **Ejemplo:** INCIBE-CERT en España, que da soporte a empresas y ciudadanos ante ciberincidentes.



Gestión de incidentes

Roles y responsabilidades

- **SOC (Security Operations Center)**

- Centro de operaciones 24/7 donde un equipo monitoriza y gestiona la seguridad en tiempo real.
- **Responsabilidades principales:**
 - Monitorización de logs y sistemas.
 - Uso de SIEM para correlación de eventos.
 - Detección temprana de amenazas.
 - Escalado de incidentes al CSIRT cuando son graves.
- **Ejemplo:** un banco tiene un SOC que detecta transacciones sospechosas y bloquea accesos no autorizados.



Gestión de incidentes

Roles y responsabilidades

- **DPO (Data Protection Officer/Delegado de Protección de Datos)**
 - Figura obligatoria según RGPD en organizaciones que traten muchos datos personales sensibles.
 - **Responsabilidades principales:**
 - Velar por el cumplimiento del RGPD y LOPDGDD.
 - Informar y asesorar a la organización en protección de datos.
 - Ser punto de contacto con la AEPD y con los interesados (ciudadanos).
 - Supervisar evaluaciones de impacto en privacidad (PIA/DPIA).
 - **Ejemplo:** una universidad con expedientes académicos debe tener un DPO.



Plan de recuperación

BCP vs DRP

- **BCP (Business Continuity Plan)**

- Garantizar que la organización pueda seguir funcionando durante y después de una interrupción grave.
- Minimizar el impacto en los procesos críticos (incluso si los sistemas de TI fallan).
- **Alcance:** procesos de negocio + TI + personal + proveedores.
- **Ejemplos de medidas:**
 - Activar sede alterna para el personal.
 - Procedimientos manuales si un sistema falla.
 - Acuerdos con proveedores alternativos.



Plan de recuperación

BCP vs DRP

- **DRP (Disaster Recovery Plan)**
 - Centrado en la recuperación de sistemas tecnológicos (TI).
 - Restaurar infraestructuras críticas (servidores, redes, aplicaciones) en un tiempo aceptable.
 - **Alcance:** TI (hardware, software, datos, redes).
 - **Ejemplos de medidas:**
 - Copias de seguridad y restauración.
 - Sitio de recuperación.
 - Replicación de servidores en la nube.



Plan de recuperación

Métricas clave

- **RTO (Recovery Time Objective)**

- Tiempo máximo tolerable para recuperar un sistema o servicio tras un incidente.
- **Ejemplos:**
 - RTO de la web de matrículas online: 4 horas.
 - RTO del correo electrónico corporativo: 24 horas.

- **RPO (Recovery Point Objective)**

- Cantidad máxima de datos que la organización puede permitirse perder, medida en tiempo.
- **Ejemplo:**
 - RPO de base de datos de pagos: 15 minutos.
 - RPO de carpetas compartidas: 12 horas.